INF-806/IFT-509
Systèmes et réseaux
Cahier des charges de projet

Romain Levifve

Université de Sherbrooke

Consignes générales

- Les images doivent être légendés pour un référencement plus facile
- Les pages doivent être numérotés
- Le rapport devra être remis sur Moodle
- Le rapport peut être rédigé sous n'importe quel logiciel (Word, Google Doc, Overleaf, TexStudio, LibreOffice, etc.) tant qu'il respecte les consignes et devra être remis au format PDF
- Le rapport doit être écrit dans une police conventionnelle et consistente (une police de type sans-serif comme Arial ou Calibri pour une meilleure visibilité). La taille de la police doit être de 12 pour le contenu, et l'interligne de 1.5.
- Se référer a la présentation du thème 2 sur Moodle pour les dates de rendu du rapport
- Le rapport doit proposer 20 pages de contenu **minimum** (hors annexe, page de présentation, table des matières)
- Les acronymes (si il y en a) doivent soit être définis une première fois, ou bien faire l'objet d'une table des acronymes a placer en annexe ou après la table des matières
- Le rapport devra contenir les attributions de travail de chacun des membres ayant contribué au projets. Si il est mentionné dans les recommandations de noter l'organisation du groupe. Il est possible que certaines personnes doivent sortir de leur rôles pour aider ou accomplir plus de tâches que prévu. Le format pourra être (mais ne se limite pas à) un code couleur pour faire ressortir le travail de chacun, par exemple « **Prenom1 Nom1** a effectué telle et telle tâche tandis que **Prénom2 Nom2** s'est chargé de faire telle et telle chose ». Ou encore sous forme de table :

Prenom1 Nom1	Telle tâche
Prénom2 Nom2	Telle chose

Recommandations

- Construire son rapport de manière continue
- Tenir un journal avec des dates de rencontres/des milestones accomplies/des points bloquants majeurs rencontrés au cours du projet (à mettre en annexe)
- Définir l'organisation du groupe au préalable, si des personnes travaillent plus, ils pourront le noter dans les attributions
- Éviter de s'y prendre au dernier moment
- Démontrer que vous comprenez ce que vous implémentez, détaillez ce que vous faites
- Il est possible de revoir avec moi le rapport lors de nos périodes de cours pour des conseils ou des directions.
- L'usage du LateX pour les notations mathématiques est fortement encouragé

Structure du rapport

- La première page doit contenir le titre du rapport, les noms, les matricules étudiants, le nom du cours ainsi que la date
- Le rapport doit contenir au minimum
  - une table des matières
  - Une introduction
  - Une partie principale comprenant :
    - Un état de l'art sur les concepts utilisés dans le projet/brève présentation des technologies employés
    - La partie organisationnelle, attribution des rôles etc.
    - L'implémentation du projet ainsi que les décisions prises
    - Des potentiels points bloquants ainsi que les mitigations ou les raisons sur pourquoi cela à été mis de coté.
    - Des points non inscrit sur le cahier des charges. Si le groupe juge pertinent de rajouter des sécurités, de repérer des angles morts sur le projet et souhaite l'améliorer en dépassant les attentes
    - De simples schémas/diagrammes. Les captures d'écrans ainsi que les diagrammes et schémas plus complexes peuvent être mis en annexe
    - Des parties spécifiques aux projets spécifiés dans leurs parties respectives.
  - Une conclusion sur les notions apprises lors des recherches sur le projet
  - Des références au articles consultés, de la documentation, etc.
  - Une annexe

Requis de projet
Implémentation du SSO avec Authelia

Connaissances mobilisés

- Gestion des accès et des identités
- Réseaux
- Infrastructures

Ce projet consiste à l'implémentation du concept « Single Sign On » sur une technologie open source. L'objectif est de comprendre les mécanismes intrinsèque au standard OIDC (Open ID Connect) et ses enjeux. Comprendre ce qu'il se passe d'un point de vue infrastructure lorsqu'un système d'authentification unifié permet l'accès aux services connectés et comment ils le sont.

Enoncé

TechSolutions est une entreprise de développement logiciel de taille moyenne, spécialisée dans la création d'applications web et la fourniture de solutions cloud pour divers clients. Ils utilisent une stack technologique variée qui nécessite une gestion sécurisée des accès pour différents services.

Services à Sécuriser avec Authelia

- **GitLab**
  - **Usage** : Gestion du code source et CI/CD pour automatiser les processus de déploiement.
  - **Intégration** : Authelia est configuré comme fournisseur OpenID Connect pour gérer l'authentification de tous les développeurs et membres de l'équipe accédant au référentiel.
- **Jenkins**
  - **Usage** : Serveur d'intégration continue et de déploiement automatisé.
  - **Intégration** : En utilisant Authelia pour l'authentification, l'accès est limité au personnel autorisé uniquement, garantissant que seules certaines personnes peuvent déclencher des builds et des déploiements.
- **Nextcloud**
  - **Usage** : Solution de stockage cloud auto-hébergée pour la collaboration et le partage de fichiers.
  - **Intégration** : Authelia sécurise l'accès aux fichiers partagés au sein de l'organisation, permettant aux utilisateurs de s'authentifier facilement via leurs identifiants existants.
- **JIRA**
  - **Usage** : Outil de gestion de projet et de suivi des problèmes.
  - **Intégration** : Utilise Authelia pour un accès sécurisé et sans friction aux tableaux de projet et aux tickets, garantissant que les informations sensibles des projets sont protégées.
- **Confluence**
  - **Usage** : Logiciel de collaboration pour la documentation et le partage de connaissances entre équipes.
  - **Intégration** : En sécurisant Confluence avec Authelia, l'entreprise s'assure que seuls les utilisateurs authentifiés peuvent accéder à la documentation sensible et aux plans de projets.
- **Rocket.Chat**
  - **Usage** : Plateforme de communication d'équipe pour la messagerie en temps réel et la collaboration.
  - **Intégration** : Authelia sécurise l'accès des utilisateurs pour éviter les utilisations non autorisées, maintenant la confidentialité des discussions internes.

Voici la liste des employés

Nom de l'Utilisateur	Rôle	Accès Recommandé
Alice Dupont	Développeuse Frontend	GitLab, Jenkins, Nextcloud, JIRA, Confluence
Bob Martin	Développeur Backend	GitLab, Jenkins, Nextcloud, JIRA
Claire Leroy	Chef de Projet	JIRA, Confluence, GitLab
David Moreau	Administrateur Système	Gestion de l'infrastructure, GitLab, Jenkins, Nextcloud
Eva Bernard	Testeuse QA	GitLab (lecture seule), JIRA, Confluence
François Petit	Responsable Sécurité	Accès à tous les services pour les audits et évaluations de sécurité
Gabrielle Rousseau	Designer UI/UX	Nextcloud, JIRA, Confluence
Hugo Lefebvre	DevOps	Jenkins, GitLab, Accès aux serveurs de build
Isabelle Fontaine	Responsable Marketing	Confluence, Nextcloud
Julien Gaillard	Support Technique	JIRA, accès limité à Nextcloud (références techniques)

Infrastructure

- Monter une infrastructure comprenant **l'intégralité** des services Mentionnés plus haut :
  - Jira et Confluences sont des solutions professionnelles qui restent gratuites pour les instances de 10 utilisateurs maximum
  - La version communautaire de rocket.chat est gratuite
- L'ensemble de ces services doit être mis en arrière d'un reverse proxy (de préférence Nginx) qui interagira avec Authelia.
- Documentation :
  - Le fonctionnement de OpenID Connect 1.0
  - Les flux d'authentifications avec chacun des services
  - Les groupes utilisés et les permissions associés
  - La nomenclature d'un CIP (Code d'Identification Personnel) que vous définirez
  - Les différentes limites de login de la part des utilisations
  - Les diagrammes de de flux réseaux, ports, FQDN, etc.
  - En annexe ou en supplément dans une archive zip, la configuration d'Authelia
- Les utilisateurs devront tous utiliser du 2FA
- Le processus de réintialisation de mot de passe ne sera pas évalué
- Une connexion HTTPS (utilisation de certificats TLS) sera demandé sur le reverse proxy
- Dans le cas de figure de Docker, les tokens et informations sensibles laissé dans les fichiers de configurations seront une pénalité, les tokens et informations sensibles

externalisé dans des variables d'environnements seront considéré comme la norme pour des raisons de praticités et l'utilisation de secret apportera des points **bonus**

- **Bonus :** Authelia se sert d'un fichier pour stocker ses identifiants, configuration et mots de passe. L'utilisation d'un serveur LDAP fonctionnel en combinaison d'Authelia apportera une quantité significative de points bonus. Ce serveur peut être un Active Directory Microsoft, un serveur Zential, NethServer ou FreeLDAP. Dans le cas échéant, documenter les choix cryptographiques pour les hashes
- **Bonus** : Automatiser la rotation de tokens avec une solution d'automatisation comme Ansible